Table of Contents

1. Executive Summary:.....2
2. Threat Overview.....3
3. Attack Lifecycle:.....7
3.1: Attack Flow Diagram:.....7
3.2 Attack Lifecycle with durations:.....8
3.3 CIA Triad Impact Analysis:.....9
4. Detection Method.....10
4.1. Indicators of Compromise (IOCs): -.....10
4.2. Behavioral Indicators: -.....10
4.3 Detection Tools: -.....11
5. Mitigation.....12
5.1 Technical Controls (Priority & Cost Estimate): -.....12
5.2 Policy and Process controls: -.....13
5.3 Training & Awareness Recommendations: -.....13
5.4 Prioritized Mitigation Roadmap: -.....14
6. AI Usage Reflection.....15
6.1 AI Tools Used and Effectiveness: -.....15
6.2 What worked well: -.....15
Reference: -.....17

Topic: - Data Security Risk

Team Name: - Zero Trace.

1. Executive Summary:

In today's digital environment, data has become one of the most valuable assets for any organization. At the same time, it has also become one of the most targeted. Data security risk refers to the possibility that sensitive information may be exposed, altered, stolen, or made unavailable due to cyberattacks, system vulnerabilities, or human error. With the rise of cloud computing, remote work, and advanced attack techniques, this risk has significantly increased in recent years.
Recent incidents across healthcare, finance, and hospitality sectors show that even large organizations with established systems are vulnerable. The consequences are not limited to technical damage. Organizations may suffer financial losses, operational disruption, legal consequences, and long-term reputational harm. In many cases, the loss of customer trust becomes more damaging than the immediate breach itself.

Key Risks

- Significant financial losses resulting from operational downtime, ransom payments, legal costs, and regulatory penalties.
- Exposure of sensitive customer and organizational data leading to loss of trust and long-term reputational damage.
- Disruption of critical business operations, affecting service delivery, supply chains, and customer experience.

Top 3 Prioritized Recommendations

- Immediately strengthen identity and access management by implementing multi-factor authentication and strict privilege controls across all systems.
- Enhance monitoring and detection capabilities through centralized logging, anomaly detection, and regular vulnerability management.
- Establish a structured risk management and incident response framework supported by employee awareness training and periodic security assessments.

In conclusion, data security risk represents a critical organizational challenge that requires proactive leadership attention. By implementing structured mitigation strategies and strengthening governance practices, organizations can significantly reduce exposure and improve resilience against future threats.

2. Threat Overview

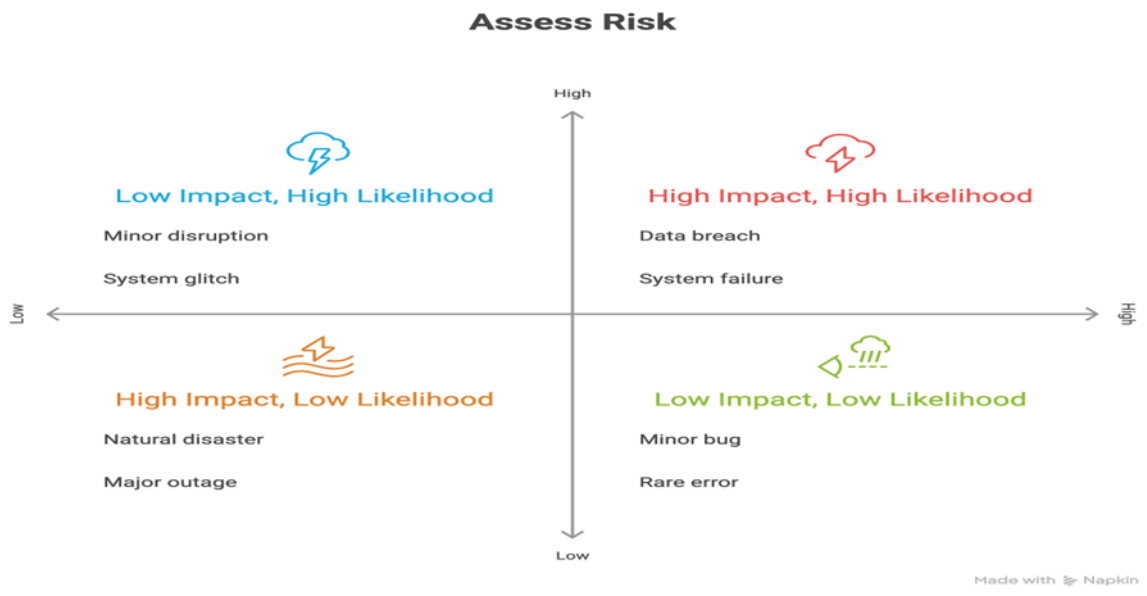
2.1 Definition and Evolution

When we started researching data security risk, we initially thought it was just about hackers stealing information. However, after analysing multiple industry reports and recent breach cases, we understood that data security risk is much broader. It refers to the possibility that sensitive organizational data may be exposed, altered, destroyed, or made unavailable due to cyberattacks, system failures, human error, or weak security controls.

In today's digital environment, almost every organization depends on data. Customer information, payment details, employee records, research documents, contracts, and cloud databases are all digitally stored. If this data is compromised, the consequences can include financial losses, legal action, reputational damage, and operational shutdown.

Over the past decade, the risk has significantly increased due to three main factors. First, the rapid adoption of cloud computing has expanded the attack surface. Second, remote work environments have reduced centralized control over security. Third, cybercriminals are now using automation and artificial intelligence to conduct attacks at scale.

From global cybersecurity reports, the average cost of a data breach in 2023 exceeded 4 million USD per incident. This shows that data security risk is not theoretical. It is financially and operationally damaging



This diagram highlights that data security risk is often influenced by underlying factors that may not always be visible.

Issue such as remote work exposure, phishing activity, cloud, misconfigurations, and weak response processes contribute significantly to increasing overall risk.
This help explains why incidents can occur even when organizations believe their systems are secure.

2.2 Technical Process

Data security risk usually starts from a small weakness. It does not always begin with a big attack.

Step 1: Initial Access

An attacker gets into the system through phishing emails, weak passwords, stolen credentials, or unpatched software.

Step 2: Gaining More Access

After entering, the attackers try to get higher permissions so they can move freely inside the networks.

Step 3: Searching for Data

They look for important information such as customer data, financial records, or internal documents.

Step 4: Data Extraction

Once they find valuable data, it is copied and sent outside the organization's networks without permission.

Sometimes systems are also locked or disrupted to increase pressure. In many cases, the organization does not immediately realize what has happened, which increase overall damage.

Overall, this process shows that data security incidents usually begin with a small weakness and gradually expands as access increases.

Each step builds on the previous one, which is why early detection is critical in reducing the overall impact. Understanding this technical flow helps in recognizing how breaches develop over time rather than appearing suddenly.

2.3 Targeted Sectors

Data security risk can affect almost any organization that stores digital information.
However, some sectors are targeted more frequently because of the type and the value of the data they manage.

SECTOR	Why They Are Targeted
Healthcare	Stores patient records, medical history, insurance details.
Financial Services	Holds banking data, transaction details, credit information
Government	Maintain citizen data and sensitive national information
Education	Large student database with limited cybersecurity budgets
Technology Companies	Intellectual property, research data, proprietary system.

Healthcare organization are often targeted because medical records contain detailed personal and financial information.

Financial institution is targeted because attackers can directly monetize the stolen data.

Government system is targeted due to the sensitivity of citizen information.

Educational institutions may have large data volumes but fewer security resources.

This demonstrates that data security risk is widespread and not limited to specific type of organization.

2.4: Case Studies

Case study 1

MOVEit Transfer - MAY2023 – Multiple Industries.

In May 2023, a critical zero-day vulnerability was discovered in MOVEit Transfer software, which is widely used for secure files transfer. The vulnerability was actively exploited before patches were fully applied. Attackers were able to access database connected to the platform and extract sensitive personal and organizational data.

Impact with numbers: - More than 2000 organizations were affected globally, and millions of individuals records were exposed, including names, Social Security numbers, and financial information.

Outcome: - Affected organizations-initiated breach notifications, regulatory reporting, and system investigations. Legal actions and compliance reviews followed in multiple regions.

Source: - Bleeping computers (2023); CISA 2023, IBM security cost of a Data Breach Report 2023.

Case study 2

MGM Resorts – September 2023 – Hospitality

In September 2023, MGM Resort experienced a cyber incident that began with unauthorized access to internal systems. The disruption affected hotel operations, casino systems, and online booking platform across several properties.

Impact with numbers: - The organization reported estimated financial losses exceeding 100million USD due to system downtime and business disruption.

Outcome: -Operations were gradually restored over several days. The organization conducted internal reviews and publicly disclosed the financial impact of the incident.

Source: - Reuters (2023); Microsoft Digital Defense Report 2023.

Case Study 3

Change Healthcare – February 2024 – Healthcare

In February 2024, change healthcare experienced a ransomware – related incident that disrupted healthcare payment processing and prescription service across the United States. The attack impacted system that connected healthcare providers, pharmacies, and insurers.

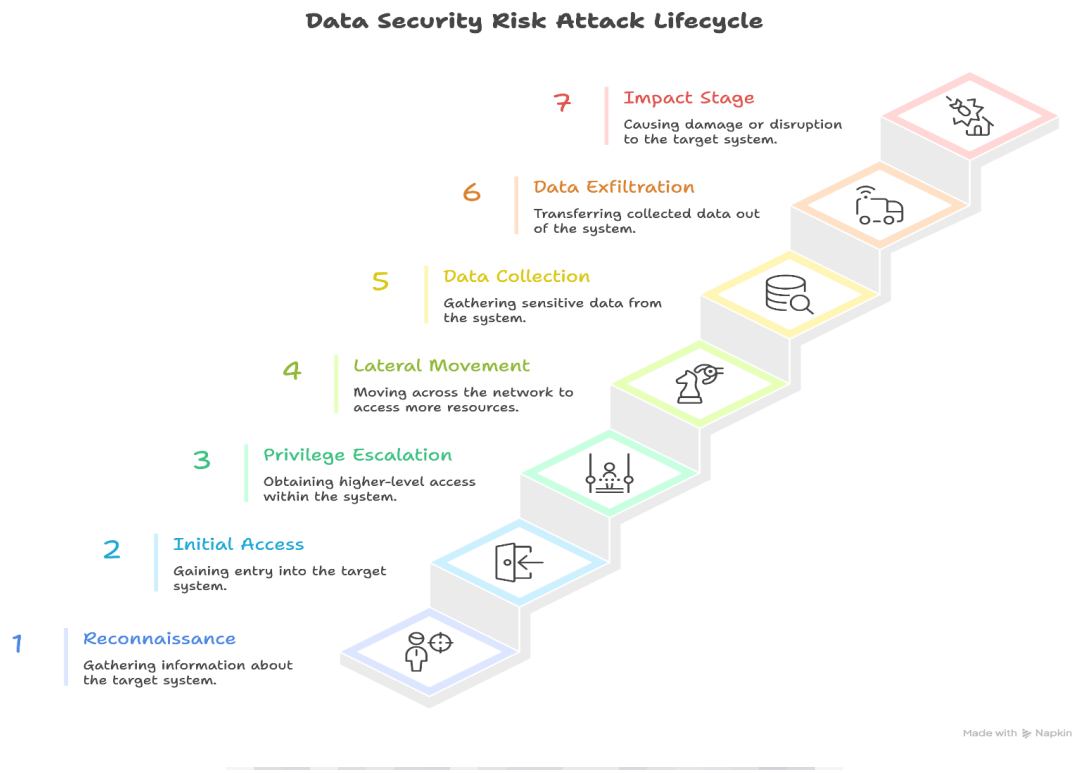
Impact with numbers: - Thousands of healthcare providers were affected nationwide, causing services delays and operational disruption. The incident impacted millions of patients records and financials transactions.

Outcome: - The organization worked to restore systems over time and coordinated with federal authorities. Services recovery occurred in phases as systems were brought back online.

Source: - U.S. Department of health & Human services (2024) ; CrowdStrike Global Threat Report 2024.

3. Attack Lifecycle:

3.1: Attack Flow Diagram:



Data Security Risk Attack Lifecycle: - The diagram above shows how a data security incident progresses through different stages, from early activity to final impact.

It highlights that such incidents usually develop gradually rather than happening suddenly. Understanding this sequence makes it easier to see where risks may appear and why it is important to monitor system continuously.

3.2 Attack Lifecycle with durations:

To understand how these stages unfold in practice, the following section explains each steps along with the typical durations and its role in the overall incident.

Stage	What Happens	Typical Duration
Reconnaissance	Information about the organization is gathered and possible entry points are identified.	Days to weeks
Initial Access	Unauthorized access is gained through a weakness such as stolen credentials or phishing	Minutes to days
Privilege Escalation	Higher access permissions are obtained to move deeper into systems	Hours to days
Lateral Movement	Internal systems are explored to locate valuable data	Several days
Data Collection	Sensitive data is identified and copied	Hours to days
Data Exfiltration	Data is transferred outside the network	Minutes to hours
Impacts Stage	Disruption or exposure becomes visible and affects operations	Immediate to ongoing

This table above show how a typical data security incident progresses over time.

Although exact timelines may vary, understanding these stages helps organizations recognize where monitoring and controls should be placed. Early detection during initials stages can significantly reduce the overall impact.

In many real-world situations, organizations may not detect unusual activity until later stages, which increases the severity of the incident. By understanding how each phase progresses over time, it becomes easier to recognize why continuous monitoring and awareness are important in reducing potential damage.

3.3 CIA Triad Impact Analysis:

The CIA triad helps explain how data security incidents affect different aspects of information security.

CIA Component	Impact Level	Explanation
Confidentiality	High	Sensitive information such as customer records, financial data, may be exposed or accessed without authorization during a data security incident
Integrity	High	Data can be modified, corrupted, or manipulated which may affect accuracy and trust in organizational systems and records
Availability	High	System or service may become unavailable due to disruption, shutdown, or operational impact, affecting normal business activities.

This mapping shows that data security incidents can affect multiple aspects of information security simultaneously, increasing overall organizational risk.

4. Detection Method

4.1. Indicators of Compromise (IOCs): -

Indicators of Compromise are observable signs that suggest a system may have been exposed to unauthorized activity. These indicators help security teams identify patterns that could indicate a breach or suspicious behaviour. Monitoring such indicators allows organizations to investigate potential threats before they escalate.

IOC Example

Indicator Type	Example	Why it Matters
IP Address	185.220.101.45	Repeated connection attempts from unusual location
IP Address	103.27.109.12	Unexpected outbound traffic
Domain	Secure-update-login.com	Possible phishing or malicious redirection
File Hash (SHA-256)	3b83fe3e…. (shortened for readability)	Unknown executable detected
File Hash (MD5)	098f6bcd… (shortened for readability)	Suspicious file modification

These examples show how technical indicators can provide early signs of compromise. Regular monitoring and updating of threat intelligence sources help maintain effectiveness**.**

4.2. Behavioral Indicators: -

Behavioral indicators focus on noticing activities that look unusual compared to normal system behavior. Even if there are no clear technical signs, changes in how users or systems operate can indicate that something is wrong. For example, repeated login failures within a short time may suggest someone is trying to guess passwords. Similarly, if a user suddenly accesses large amounts of sensitive data or logs in from a different location than usual, it may indicate unauthorized access.

Other warning signs include unexpected privilege changes, creation of new administrator accounts, or large data transfers outside normal working hours. Monitoring these patterns helps organizations detect potential incidents early because attackers often try to blend in with normal activity. Paying attention to unusual behavior allows security teams to investigate before serious damage occurs.

4.3 Detection Tools: -

- **Wazuh: -**

  Use: Log monitoring and threat detection

  What it does: Collects and analyzes system logs to identify suspicious activity, unauthorized changes, and potential security incidents.

- **Snort: -**

  Use: Network intrusion detection

  What it does: Monitors network traffic and detects unusual or malicious patterns that may indicate unauthorized access attempts.

- **Suricata: -**

  Use: Network monitoring and traffic analysis

  What it does: Provides real-time inspection of network data to identify suspicious behavior and potential threats.

- **OSSEC: -**

  Use: Host-based intrusion detection

  What it does: Monitors system activity, file integrity, and user behavior to detect unauthorized modifications.

- **Wireshark: -**

  Use: Packet analysis and troubleshooting

  What it does: Captures and analyzes network packets to help identify unusual communication or potential security issues.

- **OpenVAS: -**

  Use: Vulnerability scanning

  What it does: Scans systems for known vulnerabilities that could be exploited by attacker

5. Mitigation

5.1 Technical Controls (Priority & Cost Estimate): -

Technical controls are measures implemented within systems and infrastructure to reduce vulnerabilities and detect suspicious activity.

Control	Purpose	Priority	Cost Level
Multi-factor Authentication (MFA)	Prevent unauthorize access even if credentials are compromised	High	low
Regular Patch Management	Fixes known vulnerability in software	High	Low
Data Encryption	Protects sensitive data from unauthorized access	High	Medium
Network Monitoring	Detect unusual traffic patterns	High	Medium
Backup & Recovery System	Ensure data can be restored after incidents	High	Medium
Access Control (Least Privilege)	Limits user permissions to necessary functions	Medium	Low
Vulnerability Scanning	Identifies system weakness	Medium	Low

These controls help reduce attack opportunities and improve system resilience without requiring excessive investment.

5.2 Policy and Process controls: -

In addition to technical measures, strong governance practices are essential to maintain security. Clear policies help define responsibilities and ensure consistent handling of risks. Organizations should establish access management policies that define how user permissions are granted and reviewed.

Incident response procedures should clearly outline steps to follow when suspicious activity is detected, including communication channels and escalation paths.

Data classification policies help identify sensitive information so that appropriate protections can be applied.

Regular audits and security reviews are also important to ensure compliance with internal policies and regulatory requirements.

Having well-defined processes reduces confusion during incidents and improves overall response effectiveness.

In addition, organizations should ensure that policies are regularly updated to reflect changes in technology, business operations, and emerging risks. Periodic policy reviews help confirm that procedures remain relevant and practical for daily use. Encouraging cross-department communication also improves policy effectiveness, as different teams may identify gaps or challenges during implementation. Maintaining clear documentation and version control ensures that employees always have access to the most current guidance, which supports consistency and strengthens overall governance across the organization

5.3 Training & Awareness Recommendations: -

Training and Awareness Recommendations

Human error remains one of the most common causes of data security incidents.

Providing regular training helps employees recognize risks and respond appropriately.

Security awareness sessions should educate employees about phishing attempts, password hygiene, and safe data handling practices.

Simulated phishing exercises can help reinforce learning and improve detection of suspicious emails.

Training should also include guidance on reporting unusual activity promptly.

For technical teams, periodic workshops on secure configuration and incident handling can strengthen response capabilities.

Continuous learning ensures that both technical staff and general users remain aware of evolving threats.

Organizations should also encourage employees to report anything unusual without worrying about making mistakes. When people feel comfortable speaking up, potential issues can be identified much earlier. Providing short refresher sessions from time to time helps keep security awareness fresh in everyone’s mind. Regular reminders through emails or meetings can reinforce safe practices and make employees more confident in handling sensitive information responsibly as part of their daily work.

5.4 Prioritized Mitigation Roadmap: -

Implementing mitigation measure in phases allows organizations to focus on immediate risks while planning long-term improvements.

- **Immediate Actions (0-30 days): -**

Action	Objective
Enable multi-factor authentication	Reduce unauthorized
Apply critical security	Address known vulnerabilities
Review user access permissions	Remove unnecessary privileges
Verify backup availability	Ensure recovery capability

These steps provide quick risk reduction with minimal effort.

- **Short- Term Actions (1-3 Months): -**

Action	Objective
Deploy centralized logging	Improve visibility into system activity
Conduct employee security training	Reduce human- related risks
Implement vulnerability scanning	Identify security gaps
Test incident response procedure	Improve readiness

Short- term improvement strengthen monitoring and preparedness.

- **Long – Term Actions (Beyond 3 Months): -**

Action	Objective
Implement continuous monitoring tools	Enhance threat detection
Perform periodic security audits	Maintain compliance
Improve network segmentation	Limit potential spread of incidents
Develop security culture initiatives	Promote ongoing awareness

Long – term measures support sustainable security practices.

6. AI Usage Reflection

6.1 AI Tools Used and Effectiveness: -

While working on this project, we used AI mainly as a support tool to help us understand concepts more clearly and organize our thoughts while writing different sections of the report. Since the topic of data security risk involves multiple areas such as risk assessment, CIA triad mapping, detection methods, and mitigation planning, AI helped us explore these topics in a structured way. found it especially useful when we needed to simplify technical explanations or check whether was covering all required points. Overall, the rate its effectiveness as high because it supported our learning process and made it easier to manage the workload, although we still reviewed everything carefully to ensure it reflected our understanding.

6.2 What worked well: -

One of the things that worked really well during this project was how AI helped us understand complex cybersecurity concepts in a simpler and more practical way. Since this was our first time working on a structured threat intelligence report, having guidance on how to approach sections like risk analysis, detection methods, and mitigation made the process much smoother. It allowed us to discuss ideas more confidently as a team and refine our understanding as we progressed.

We also used Napkin AI for the first time to create visual diagrams such as the attack lifecycle and risk visuals. It was honestly a very eye-opening experience because it helped us visualize concepts that were otherwise difficult to explain in text. Seeing the flow of an incident visually made it much easier to understand how different stages connect, and it improved the clarity of our report.

Another area where AI worked well was in helping us plan the project. Based on the guidance and templates provided in the IIT project files, AI helped us think through a structured approach and roadmap to complete different sections step by step. This made it easier to manage deadlines and ensured that we covered all required components without missing anything.

AI also supported us in organizing content, creating tables, and reviewing sections for clarity. Overall, it acted as a helpful assistant that guided our workflow while still allowing us to contribute our own understanding.

6.3 Where AI Fell short: -

While AI was helpful throughout the project, there were moments where we noticed its limitations. Sometimes the responses were too general and did not fully match the specific instructions provided in the project guidelines, which meant we had to carefully review and refine the content. In certain cases, AI suggested explanations that were either too detailed or not aligned with the expected format, so we needed to simplify and adjust them based on our understanding.

Another challenge was that AI cannot fully interpret the grading expectations or the context of our project, especially when working with the templates provided by IIT. We had to cross-check whether the content actually fit the required sections and ensure that nothing important was missed. While using Napkin AI for diagrams was very helpful, we still needed to review the visuals and make sure they accurately reflected what we wanted to communicate.

Overall, we realized that AI is a strong support tool, but it still requires careful human judgment and verification.

6.4 Team collaborations and Prompt Used: -

Throughout the project, we used AI individually according to our responsibilities while also sharing general ideas about how it could support our work. Indrajit, as the Risk Analyst, focused on understanding risk impact, CIA mapping, and mitigation strategies.

Chaitanya, the Assessment Coordinator, reviewed whether our content aligned with project requirements. Mitrasen, as Scrum Master, helped manage progress and coordination, while Pushpendra, the Documentation Lead, worked on maintaining consistency and clarity in the report.

Some of the prompts we used included:

Risk Analyst prompts:

- You are a cybersecurity risk analyst. Explain how data breaches impact the CIA triad with real-world examples in paragraph format.
- Provide realistic mitigation strategies with priority and cost.

Assessment Coordinator prompts:

- Check whether a cybersecurity report meets assignment criteria.
- How to evaluate completeness of risk analysis.

Scrum Master prompts:

- Best practices for tracking project tasks in agile workflow.
- How to coordinate team deliverables effectively.

Documentation Lead prompts:

- How to structure a technical report clearly.
- Tips for maintaining consistency across sections.

Sharing these approaches helped us stay aligned and supported collaboration while still contributing individually.

6.5 key Lessons Learned

Through this project, we learned that AI can save a lot of time when used properly and can help maintain a clear workflow while managing different tasks. It acted as a supportive partner by helping us find useful resources such as videos, articles, and links that made it easier to understand complex topics. At the same time, we realized that AI should not be trusted blindly. While it is very helpful, relying too much without reviewing can lead to mistakes, so careful checking is always important.

We also found that AI helped us review our work and organize the report in a structured way according to the requirements. Using tools like Napkin AI improved our understanding by allowing us to visualize concepts that were difficult to explain, which also strengthened our teamwork. Working through the project gave us valuable experience in handling responsibilities, following a proper roadmap, and learning how to use AI effectively while still applying our own thinking.

Reference: -

1. IBM Security. (2023). Cost of a Data Breach Report 2023. IBM.
2. Verizon. (2023). Data Breach Investigations Report (DBIR). Verizon.
3. CISA. (2023). Ransomware Guide. Cybersecurity and Infrastructure Security Agency.
4. ENISA. (2023). ENISA Threat Landscape Report. European Union Agency for Cybersecurity.
5. Microsoft. (2023). Microsoft Digital Defense Report. Microsoft Security.
6. NIST. (2024). Cybersecurity Framework. National Institute of Standards and Technology.
7. CrowdStrike. (2024). Global Threat Report. CrowdStrike.
8. U.S. Department of Health & Human Services. (2024). Change Healthcare Cyber Incident Information.
9. BleepingComputer. (2023). MOVEit Transfer Data Breach Coverage.

Full URLs available upon request